Dispensa Lezione 3: Infrastructure Security

Introduzione

In questa lezione, ci focalizzeremo sugli attacchi destinati all'infrastruttura di rete. In particolare, copriremo attacchi alle LAN e ai principali protocolli di livello 3 dello stack TCP/IP.

Fondamenti di Rete

Per comprendere come un'infrastruttura possa essere compromessa, è indispensabile padroneggiare il suo funzionamento in condizioni di normalità. In questo capitolo ripasseremo i concetti architetturali alla base delle comunicazioni locali e geografiche, focalizzandoci sui protocolli e sui meccanismi che governano il Data Link Layer e il Network Layer del modello OSI.

Identità in Rete: Indirizzamento Fisico e Logico

La comunicazione di rete si basa su un sistema di doppio indirizzamento, necessario per gestire sia la consegna locale (all'interno dello stesso segmento) sia l'instradamento globale (attraverso reti diverse).

- **MAC Address (Media Access Control): L'Indirizzo Fisico (Layer 2)**
  - È un identificatore univoco a 48 bit, tipicamente espresso in formato esadecimale (es. `00:1A:2B:3C:4D:5E`).
  - È "bruciato" (burned-in) nella scheda di rete (NIC) dal produttore e opera esclusivamente a livello di rete locale (LAN).
  - I primi 24 bit rappresentano l'OUI (Organizationally Unique Identifier), che identifica il vendor, mentre i restanti 24 bit sono assegnati specificamente a quella singola interfaccia.
- **IP Address (Internet Protocol): L'Indirizzo Logico (Layer 3)**
  - Nel caso dell'IPv4, è un indirizzo gerarchico a 32 bit, diviso in quattro ottetti decimali (es. `192.168.1.10`).

- A differenza del MAC, l'IP non è legato all'hardware ma è assegnato logicamente (staticamente o dinamicamente via DHCP) e definisce sia la rete di appartenenza (Network ID) sia lo specifico host (Host ID).
- È essenziale per il routing: permette ai router di inoltrare i pacchetti tra reti geograficamente o logicamente separate.

La Meccanica dello Switch

Lo switch è il cuore nevralgico della LAN moderna. A differenza del vecchio hub, che replicava ogni segnale elettrico su tutte le porte (causando collisioni e inefficienze), lo switch è un apparato intelligente che inoltra i frame Layer 2 in modo selettivo.

Il suo funzionamento si basa sulla **MAC Address Table** (o CAM Table):

1. **Apprendimento (Learning):** Quando uno switch riceve un frame, legge il MAC address *sorgente* e lo associa alla porta fisica da cui è entrato, salvando questa informazione nella sua tabella.
2. **Inoltro (Forwarding):** Lo switch consulta poi il MAC address *destinazione* del frame. Se questo indirizzo è presente nella sua tabella, inoltra il frame esclusivamente alla porta associata.
3. **Flooding:** Se il MAC destinazione non è presente nella tabella (Unknown Unicast), oppure se si tratta di un indirizzo di Broadcast (es. FF : FF : FF : FF : FF : FF), lo switch inoltra il frame su tutte le porte attive, ad eccezione di quella da cui lo ha ricevuto.

Il Protocollo ARP: Il Ponte tra Logico e Fisico

Affinché un host A possa inviare un pacchetto IP a un host B sulla stessa rete locale, deve prima incapsulare il pacchetto in un frame Ethernet. Per farlo, ha bisogno di conoscere il MAC address di B. Qui entra in gioco l'**ARP (Address Resolution Protocol)**.

Il processo di risoluzione avviene in due fasi:

1. **ARP Request:** L'host A invia un messaggio in broadcast (FF : FF : FF : FF : FF : FF) a tutta la sottorete chiedendo: *"Chi ha l'indirizzo IP 192.168.1.50? Risponda indicando il proprio MAC address"*.
2. **ARP Reply:** L'host B (e solo lui) riconosce il proprio IP, genera una risposta unicast diretta all'host A comunicando il proprio MAC address.

Una volta ricevuta la risposta, l'host A salva l'associazione IP-MAC nella propria **ARP Cache** locale, in modo da non dover ripetere la richiesta per le comunicazioni successive a breve termine.

La Vulnerabilità di ARP

Se dal punto di vista operativo l'ARP è un capolavoro di efficienza, dal punto di vista della sicurezza è un protocollo intrinsecamente vulnerabile. È stato progettato con un'architettura **stateless** (senza memoria di stato) e si basa sul principio della totale "fiducia implicita" (implicit trust).

Le due debolezze architetturali fondamentali che un Penetration Tester sfrutta sono:

1. **Mancanza di Autenticazione:** Non esiste alcun meccanismo crittografico per verificare che l'host che invia un messaggio ARP sia effettivamente il legittimo proprietario di quell'indirizzo IP.
2. **Accettazione Acritica:** Un host aggiornerà la propria cache ARP anche se riceve una *ARP Reply* non sollecitata (ovvero, senza aver mai inviato una precedente *ARP Request*).

Questa dinamica viene spesso innescata abusando dei **Gratuitous ARP**, ovvero messaggi di broadcast legittimi usati tipicamente dagli apparati di rete per annunciare un cambio di indirizzo MAC (es. in scenari di failover come l'HSRP) o per rilevare conflitti IP.

ARP Spoofing (o ARP Poisoning): L'Attacco

L'attacco di **ARP Spoofing** consiste nell'inviare pacchetti ARP forgiati (falsificati) sulla rete locale per "avvelenare" (poisoning) la cache ARP degli host target.

La dinamica dell'attacco: L'attaccante vuole intercettare il traffico tra una Vittima (es. `192.168.1.50`) e il Default Gateway (es. `192.168.1.1`).

1. L'attaccante invia una *ARP Reply* falsificata alla Vittima dichiarando: *"Il MAC address dell'IP 192.168.1.1 (Gateway) è il mio MAC address"*.
2. Parallelamente, l'attaccante invia una *ARP Reply* falsificata al Gateway dichiarando: *"Il MAC address dell'IP 192.168.1.50 (Vittima) è il mio MAC address"*.

Gli impatti principali:

- **Man-in-the-Middle (MitM):** Tutto il traffico in uscita dalla vittima e diretto verso internet passerà prima attraverso la macchina dell'attaccante (che agirà da router invisibile facendo IP forwarding). Questo permette lo *sniffing* di credenziali in chiaro, il dirottamento di sessioni e la manipolazione dei pacchetti in transito.
- **Denial of Service (DoS):** Se l'attaccante associa l'IP del gateway a un MAC address inesistente (o semplicemente non inoltra i pacchetti intercettati), la vittima subisce un *blackholing* del traffico, perdendo totalmente la connettività esterna.

Contromisure e Mitigazioni Architetturali

In un ambiente enterprise o durante un'attività di remediation post-VA/PT, la sicurezza del Layer 2 non può essere affidata al caso. Le difese si dividono in operative e infrastrutturali:

- **Tabelle ARP Statiche (Mitigazione Operativa):** Consiste nel forzare manualmente l'associazione IP-MAC nei sistemi operativi degli host critici o sul router (`arp -s` su Windows/Linux). È una soluzione invulnerabile allo spoofing, ma assolutamente **non scalabile** e inadatta a reti dinamiche con client DHCP. Viene usata solo in casi limite (es. tra due server ad altissima criticità).
- **Dynamic ARP Inspection - DAI (Mitigazione Infrastrutturale):** È lo standard de facto per la difesa a livello enterprise. Il DAI è una feature di sicurezza configurabile sugli switch (come i Cisco Catalyst o la serie 8000v) che intercetta tutti i pacchetti ARP in transito sulle porte non fidate (untrusted).
    - **Come funziona:** Lo switch analizza ogni pacchetto ARP e lo scarta se rileva che il MAC address e l'IP address non corrispondono a un'associazione legittima.
    - **Da dove prende le informazioni valide?** Il DAI lavora in tandem con il **DHCP Snooping Binding Database**, una tabella costruita dallo switch osservando le normali transazioni DHCP. Se un host ha regolarmente ottenuto un IP dal server DHCP, lo switch sa esattamente quale MAC address è autorizzato a usare quell'IP. Se arriva un pacchetto ARP anomalo, viene bloccato, l'evento viene loggato e la porta può essere messa in stato di *err-disable*.

Il Sistema DNS: La Risoluzione dei Nomi

Mentre macchine e router ragionano per indirizzi IP e MAC, gli esseri umani utilizzano nomi mnemonici (es. `www.azienda.local`). Il **Domain Name System (DNS)** è l'infrastruttura globale e gerarchica (Layer 7) che si occupa di questa traduzione.

- **Funzionamento:** Quando un client deve raggiungere un dominio, il suo resolver locale invia una query (tipicamente UDP sulla porta 53) al server DNS configurato (spesso fornito dal DHCP).
- **Risoluzione:** Se il server DNS locale possiede l'informazione nella sua cache o nella sua zona autoritativa, risponde immediatamente con l'indirizzo IP corrispondente. Altrimenti, interroga ricorsivamente altri server DNS (Root servers, TLD servers, Authoritative servers) fino a ottenere la risposta da inoltrare al client.
- Il corretto funzionamento del DNS è vitale: senza di esso, sebbene la connettività di base (Layer 3) sia intatta, la navigazione e l'accesso ai servizi risultano di fatto impossibili per un utente standard.

Ripasso Teorico: Il Protocollo DHCP

Il **Dynamic Host Configuration Protocol (DHCP)** è un protocollo di tipo client-server che automatizza l'assegnazione degli indirizzi IP e di altri parametri di rete critici. Senza DHCP, ogni dispositivo dovrebbe essere configurato manualmente (Static IP), rendendo la gestione di reti moderne virtualmente impossibile.

Funzionamento e Porte

Il DHCP opera a livello applicativo (Layer 7) ma interagisce direttamente con i livelli inferiori per la consegna dei pacchetti quando l'host non ha ancora un'identità logica.

- **Protocollo di Trasporto:** UDP.
- **Porta Server:** 67 (ascolta le richieste dei client).
- **Porta Client:** 68 (riceve le risposte dal server).

Il Processo DORA

La transazione standard tra un client e un server DHCP avviene in quattro fasi principali, riassunte dall'acronimo **DORA**:

1. **D**iscover (Client -> Server): L'host appena connesso invia un pacchetto in broadcast (`255.255.255.255`) per individuare i server DHCP disponibili nella rete locale.
2. **O**ffer (Server -> Client): Uno o più server rispondono proponendo una configurazione (IP, Subnet, Gateway). A questo livello, l'IP non è ancora assegnato, è solo "prenotato".
3. **R**equest (Client -> Server): Il client accetta formalmente una delle offerte ricevute (solitamente la prima) inviando un altro broadcast. Questo serve anche a informare gli altri eventuali server DHCP che la loro offerta non è stata scelta.
4. **A**cknowledge (Server -> Client): Il server conferma l'assegnazione e invia i dettagli finali. Da questo momento l'host è ufficialmente configurato.

Il Concetto di Lease (Locazione)

L'indirizzo IP non viene regalato al client, ma "affittato" per un tempo determinato, chiamato **Lease Time**.

- **T1 (Renewal):** Al 50% della durata del lease, il client tenta di rinnovarlo contattando il server in unicast.
- **T2 (Rebinding):** Se il server non risponde, all'87.5% della durata il client invia un broadcast per cercare *qualsiasi* server DHCP che possa estendere il lease.
- **Expiration:** Se il tempo scade senza rinnovo, l'host perde l'IP e deve ricominciare il processo dal Discover.

DHCP Relay Agent

In reti enterprise segmentate, il server DHCP spesso non risiede nella stessa VLAN dei client. Poiché i broadcast non superano i router, si utilizza il **DHCP Relay** (comando Cisco `ip helper-address`). Il router riceve il broadcast del client, lo trasforma in un pacchetto unicast e lo instrada verso l'IP del server DHCP remoto.

- *Nota per il VA/PT:* Il Relay Agent aggiunge informazioni al pacchetto (come l'indirizzo dell'interfaccia sorgente), permettendo al server di capire da quale pool deve pescare l'IP.

First Hop Redundancy

In un'infrastruttura di rete tradizionale, il Default Gateway rappresenta un critico *single point of failure* (punto singolo di guasto). Se l'interfaccia del router che funge da gateway si disconnette o subisce un disservizio, l'intero segmento di rete locale perde la capacità di comunicare con l'esterno, indipendentemente dalla stabilità del resto dell'infrastruttura.

Per mitigare questo rischio ingegneristico sono stati sviluppati i protocolli della famiglia FHRP (First Hop Redundancy Protocol). Tra questi, l'**HSRP (Hot Standby Router Protocol)** è lo standard proprietario Cisco più diffuso. L'obiettivo dell'HSRP è garantire un failover trasparente e immediato, raggruppando più router fisici all'interno di un unico cluster logico.

Architettura e Funzionamento dell'HSRP

In una topologia HSRP, due o più router collaborano per presentarsi agli host della LAN come un singolo "Virtual Router". Questo apparato virtuale è definito da due elementi fondamentali:

- **Virtual IP (VIP):** Un indirizzo IP logico condiviso tra i router del gruppo. Questo è l'indirizzo che viene configurato come default gateway sui client (staticamente o tramite DHCP).
- **Virtual MAC Address:** Un indirizzo fisico generato algoritmicamente e associato al VIP. Nelle implementazioni classiche (HSRPv1), ha il formato `0000.0c07.acXX`, dove gli ultimi due caratteri esadecimali rappresentano l'ID del gruppo HSRP.

Il Processo Elettivo: Affinché non ci siano conflitti di instradamento, i router del gruppo eleggono un **Active Router**, che si assume l'onere esclusivo di inoltrare il traffico destinato al Virtual MAC, e uno **Standby Router**, che rimane in ascolto pronto a subentrare in caso di guasto.

L'elezione si basa su un valore di **Priority** (da 0 a 255, con 100 come valore di default). Il router con la priorità più alta vince. Per mantenere l'accordo sullo stato del cluster, i router si scambiano periodicamente pacchetti di *Hello* in multicast (all'indirizzo `224.0.0.2` su porta UDP 1985). Se lo Standby Router smette di ricevere i pacchetti Hello dall'Active Router per un tempo superiore all'*Hold Time* (di default 10 secondi), dichiara il leader caduto e assume immediatamente il ruolo attivo.

Vulnerabilità HSRP: Il Takeover del Gateway

Esattamente come per l'ARP, l'HSRP nativo è stato concepito in un'era di totale fiducia infrastrutturale. Nelle sue configurazioni di base, l'HSRP è privo di autenticazione o utilizza, al massimo, una debole autenticazione in chiaro (spesso lasciata sul default "cisco").

Questa debolezza espone la rete a un attacco critico di **HSRP Takeover**. Un Penetration Tester (o un attaccante) posizionato nello stesso dominio di broadcast può sfruttare le dinamiche del protocollo per diventare lui stesso il Default Gateway della rete.

La dinamica dell'attacco:

1. **Reconnaissance:** L'attaccante si mette in ascolto passivo sulla rete catturando i pacchetti multicast `224.0.0.2`. Ispezionando gli *Hello* packet dell'HSRP, estrapola il Virtual IP, l'ID del gruppo, l'indirizzo IP del router attivo, la sua priorità e l'eventuale password in chiaro.
2. **Injection (Takeover):** Utilizzando tool di network injection (come *Yersinia* o script Scapy personalizzati), l'attaccante inizia a trasmettere messaggi di *Hello* contraffatti sulla rete, dichiarando di appartenere allo stesso gruppo HSRP, conoscendo la password corretta, ma impostando una **Priority massima (255)**.
3. **Preemption:** Se sui router legittimi è abilitata la funzione di *Preemption* (una feature che permette a un router con priorità superiore di spodestare immediatamente il leader attuale senza aspettare che cada), la macchina dell'attaccante viene eletta istantaneamente nuovo Active Router.

Gli impatti principali: A questo punto, tutti i client della rete invieranno il loro traffico in uscita alla macchina dell'attaccante. Questo scenario permette un attacco Man-in-the-Middle perfetto su scala di rete, consentendo l'intercettazione, l'alterazione o il blocco (DoS) del traffico verso internet o verso altre VLAN.

Contromisure: Blindare la Ridondanza

La mitigazione degli attacchi contro i protocolli di routing e ridondanza richiede di eliminare la "fiducia cieca" e imporre una validazione rigorosa dei messaggi.

- **Autenticazione Crittografica:** La soluzione definitiva è abbandonare l'autenticazione in chiaro (o la sua assenza) e configurare l'autenticazione basata su **MD5** (o algoritmi superiori se supportati) per il gruppo HSRP. In questo modo, ogni pacchetto *Hello* include un hash crittografico basato su una chiave segreta condivisa tra i soli router legittimi. Eventuali pacchetti iniettati da un attaccante verranno immediatamente scartati dal cluster, poiché l'attaccante non possiede la chiave per generare l'hash corretto.

- **Filtri Multicast e ACL:** Aggiungere Access Control List sulle interfacce di switch e router per limitare quali porte fisiche possono originare traffico multicast destinato all'indirizzo `224.0.0.2`

Ottima scelta strategica. Lavorare a coppie sui Cisco 2960 fisici con le VM in bridge abbatte il carico computazionale e simula un environment "bare metal" molto più realistico rispetto alle reti virtuali chiuse.

Per mantenere la continuità con la stesura precedente, nominerò questa sezione "Capitolo 3", dato che il Capitolo 2 lo abbiamo dedicato alla teoria e agli attacchi HSRP.

Ecco la dispensa per il laboratorio.

Laboratorio Pratico - ARP Spoofing, Phishing e Mitigazioni Layer 2

Questo laboratorio trasforma i concetti teorici di vulnerabilità del Layer 2 in un attacco reale. Lavorerete in coppie: uno studente assumerà il ruolo dell'attaccante (Red Team), l'altro quello della vittima. Successivamente, consoliderete l'infrastruttura implementando le contromisure sugli switch Cisco 2960.

Setup dell'Ambiente: VirtualBox in "Bridged Mode"

Di default, VirtualBox configura le interfacce di rete in modalità NAT, creando una rete isolata dove la VM esce su internet "dietro" l'host fisico. Per gli attacchi Layer 2 (come l'ARP Spoofing), l'attaccante deve risiedere nello **stesso dominio di broadcast** della vittima. È quindi necessario "ponticellare" la scheda di rete virtuale di Kali con quella fisica del vostro PC, connessa allo switch Cisco.

Procedura su VirtualBox:

1. Spegnete la macchina virtuale Kali Linux.
2. Aprite le **Impostazioni** della VM e andate nella sezione **Rete**.
3. Alla voce **Connesso a**, selezionate dal menu a tendina **Scheda con bridge** (Bridged Adapter).
4. Alla voce **Nome**, selezionate la scheda di rete Ethernet fisica del vostro host (quella fisicamente cablata allo switch 2960).
5. Espandete la sezione **Avanzate** e, alla voce **Modalità promiscua**, selezionate **Permetti a tutte** (Allow All). Questo è cruciale per permettere alla scheda di catturare il traffico non destinato direttamente al suo MAC address durante lo sniffing.

6. Avviate Kali e verificate di aver ottenuto un IP dalla rete del laboratorio (`ip a`).

Fase di Attacco: Man-in-the-Middle e Credential Harvesting

In questa fase, l'attaccante intercetterà il traffico della vittima e clonerà una pagina di login per sottrarre le credenziali.

Step 1: Abilitare l'IP Forwarding

Prima di "avvelenare" la rete, l'attaccante deve istruire il proprio kernel Linux a instradare i pacchetti. Se non lo si fa, il traffico della vittima verrebbe droppato dalla macchina dell'attaccante, causando un Denial of Service (la vittima non navigherebbe più) e rivelando l'attacco.

Da terminale su Kali (come root):

Bash

```
echo 1 > /proc/sys/net/ipv4/ip_forward
```

Step 2: Esecuzione dell'ARP Spoofing

Utilizzeremo la suite `dsniff`. Assumiamo che:

- `eth0` = interfaccia di Kali
- `192.168.1.50` = IP della Vittima
- `192.168.1.254` = IP del Default Gateway

L'attaccante deve aprire due finestre di terminale per ingannare entrambe le direzioni:

Terminale 1 (Inganna la Vittima):

Bash

```
arpspoof -i eth0 -t 192.168.1.50 192.168.1.254
```

Terminale 2 (Inganna il Gateway):

Bash

```
arpspoof -i eth0 -t 192.168.1.254 192.168.1.50
```

Ora tutto il traffico tra la vittima e il gateway passa fisicamente attraverso l'interfaccia dell'attaccante.

Step 3: Clonazione del portale con SE Toolkit (SET)

Sfrutteremo il Social-Engineer Toolkit per clonare la pagina di login di Twitter e catturare le credenziali immesse dalla vittima.

1. Avviate il tool da terminale: `setoolkit`
2. Navigate il menu interattivo:
    - Selezionate 1 (Social-Engineering Attacks)
    - Selezionate 2 (Website Attack Vectors)
    - Selezionate 3 (Credential Harvester Attack Method)
    - Selezionate 2 (Site Cloner)
3. **IP address for the POST back:** Inserite l'IP della vostra macchina Kali.
4. **Enter the url to clone:** Inserite `http://twitter.com` (o la pagina di login esatta).

Nota Tecnica: Nel web moderno, domini come Twitter implementano HSTS (HTTP Strict Transport Security), che forza la crittografia HTTPS e rende i browser restii ad accettare certificati non validi o connessioni declassate. Ai fini del laboratorio, se la vittima naviga direttamente sull'IP dell'attaccante (o tramite una regola di DNS Spoofing associata per un dominio http-only), vedrà la pagina clonata e i log di SET registreranno la password in chiaro non appena la vittima tenterà il login.

L'ARP Spoofing ci permette di ricevere i pacchetti della vittima, ma il **DNS Spoofing** ci permette di decidere dove la vittima debba andare quando digita un URL (es. `www.google.it`). In questo scenario, noi agiremo come un server DNS malevolo che fornisce risposte falsificate.

1. Preparazione dell'Attaccante (Kali)

Per prima cosa, dobbiamo assicurarci che le richieste DNS della vittima non raggiungano mai il server DNS legittimo (come quello di Google `8.8.8.8`). Usiamo **IPtables** per intercettare e bloccare il traffico DNS (porta 53 UDP) che la vittima tenta di inoltrare:

Bash

Blocca il traffico DNS in uscita dalla vittima che stiamo inoltrando

sudo iptables -A FORWARD -p udp --dport 53 -j DROP

Successivamente, creiamo un file di configurazione (spesso chiamato `hosts.txt`) che indichi al nostro tool di spoofing (come `dnschef` o `ettercap`) quale dominio dirottare verso il nostro IP:

Esempio file `hosts.txt`: `<ip-attaccante> www.target-domain.com`
`10.10.10.11 www.google.it`

2. Esecuzione dell'Attacco

Lanciamo `dnsspoof` indicando l'interfaccia di rete e il file dei nomi creato:

Bash

```
sudo dnsspoof -i eth0 -f fake_hosts.txt
```

3. Verifica Lato Vittima (Windows/Linux)

Per testare se l'attacco sta funzionando, dobbiamo agire sulla macchina vittima. È fondamentale svuotare la cache DNS locale, altrimenti il computer userà l'indirizzo IP corretto salvato in precedenza senza chiedere al server (noi).

Su **Windows**, apri il prompt dei comandi e digita:

1. **Svuota la cache:** `ipconfig /flushdns`
2. **Interroga il dominio:** `nslookup www.google.it`

Risultato atteso: Se l'attacco ha successo, il comando `nslookup` restituirà l'indirizzo IP della macchina Kali dell'attaccante invece dell'IP reale di Google. Da questo momento, ogni tentativo di navigazione verso quel dominio porterà la vittima su un server web controllato dall'attaccante (es. una pagina di phishing).

Approfondimento: HTTPS e HSTS (Le difese moderne)

Anche se il DNS Spoofing ha successo, l'attaccante si scontrerà quasi sempre con due tecnologie che proteggono l'integrità del web.

HTTPS (HyperText Transfer Protocol Secure)

HTTPS cifra il traffico e utilizza **certificati SSL/TLS** per garantire l'identità del sito.

- **Cosa succede:** Se dirottiamo la vittima che cerca `www.google.it` sul nostro server web (Kali), il suo browser chiederà un certificato valido per quel dominio.
- **L'ostacolo:** Dato che non possediamo il certificato firmato da una CA (Certificate Authority) per Google, il browser mostrerà un enorme avviso di sicurezza (**"La connessione non è privata"**). Se la vittima non forza manualmente l'accesso, l'attacco fallisce.

HSTS (HTTP Strict Transport Security)

L'HSTS è un meccanismo di policy di sicurezza che istruisce il browser a comunicare con un sito **esclusivamente** tramite HTTPS.

- **Il funzionamento:** La prima volta che un utente visita un sito (es. Facebook), lo switch riceve un header HSTS. Da quel momento, il browser ricorderà per mesi (o anni) che quel sito non deve mai essere caricato in HTTP semplice.

- **Impatto sul DNS Spoofing:** Anche se l'attaccante prova a fare "SSL Stripping" (forzare il downgrade a HTTP), il browser si rifiuterà di caricare la pagina non cifrata. Inoltre, in presenza di HSTS, gli errori di certificato sono **non ignorabili**: l'utente non avrà nemmeno il tasto "Procedi comunque".

Fase di Difesa: Hardening del Cisco 2960

Ora che avete compreso quanto sia banale compromettere una rete "piatta", passiamo alla mitigazione. Vi collegherete in console al Cisco 2960 per implementare due livelli di sicurezza fondamentali.

Difesa 1: Port Security

Il Port Security previene il MAC Flooding e limita i movimenti laterali di un attaccante, vincolando una porta a uno specifico MAC address.

Accedete alla configurazione dell'interfaccia a cui è collegata la vittima (es. `FastEthernet 0/1`):

Cisco CLI

```
Switch> enable
Switch# configure terminal
Switch(config)# interface fa0/1
Switch(config-if)# switchport mode access
Switch(config-if)# switchport port-security
Switch(config-if)# switchport port-security maximum 1
Switch(config-if)# switchport port-security mac-address sticky
Switch(config-if)# switchport port-security violation restrict
```

- **sticky:** Lo switch apprende dinamicamente il primo MAC address che fa traffico sulla porta e lo salva in running-config come legittimo.
- **restrict:** Se l'attaccante prova a fare spoofing usando un MAC address diverso (o se si collega un altro PC alla stessa porta), lo switch droppa i pacchetti illeciti e genera un log SNMP/Syslog senza spegnere la porta (a differenza dell'opzione `shutdown`).

Difesa 2: Segmentazione tramite VLAN

L'ARP Spoofing funziona solo se attaccante e vittima condividono lo stesso dominio di broadcast. Metterli in VLAN separate distrugge alla base l'efficacia di questo attacco Layer 2.

Creiamo due VLAN e assegniamo le porte:

Cisco CLI

```
Switch(config)# vlan 10
Switch(config-vlan)# name IT_ADMIN
```

```
Switch(config-vlan)# exit

Switch(config)# vlan 20
Switch(config-vlan)# name GUEST
Switch(config-vlan)# exit

Switch(config)# interface fa0/1
Switch(config-if)# switchport access vlan 10
Switch(config-if)# exit

Switch(config)# interface fa0/2
Switch(config-if)# switchport access vlan 20
Switch(config-if)# end
```

Step di Verifica

Per assicurarvi che le difese siano attive e funzionanti, utilizzate i comandi di verifica (show) dal privilegio exec:

1. **Verifica Port Security:**

Cisco CLI

```
Switch# show port-security interface fa0/1
```

Analizzate l'output: Verificate che lo stato sia `Secure-up`, che il `Maximum MAC Addresses` sia 1 e osservate il counter dei `Security Violation` dopo aver provato a forzare un cambio di MAC address da Kali.

2. **Verifica VLAN:**

Cisco CLI

```
Switch# show vlan brief
```

Assicuratevi che le porte `fa0/1` e `fa0/2` siano isolate nelle rispettive VLAN.

3. **Il Test Definitivo:** Provate a lanciare nuovamente l'attacco `arpspoof` da Kali. Dato che i broadcast ARP (FF:FF:FF:FF:FF:FF) non superano i confini della VLAN, le *ARP Request/Reply* dell'attaccante non raggiungeranno mai la vittima, neutralizzando del tutto l'attacco.

Rilevamento e Difesa Lato Host (Sulla Macchina Vittima)

Se l'infrastruttura di rete non è protetta da misure come la Dynamic ARP Inspection, la macchina vittima può comunque utilizzare i comandi del proprio sistema operativo per rilevare un attacco di Man-in-the-Middle in corso e per immunizzarsi.

Step 1: L'Indicatore di Compromissione (Rilevamento)

Prima che il Red Team lanci l'attacco, chiedete allo studente che fa la vittima di aprire il prompt dei comandi e visualizzare la propria cache ARP "pulita":

- **Comando (Windows/Linux):** `arp -a`
- *Fate annotare il MAC address associato all'IP del Default Gateway.*

Una volta che l'attaccante ha avviato `arpspoof`, fate ripetere il comando `arp -a` alla vittima. Gli studenti dovranno notare l'evidenza dell'avvelenamento: **L'indirizzo IP del Gateway e l'indirizzo IP della macchina Kali (attaccante) presenteranno ora l'identico MAC Address.** Questo è il segnale inequivocabile che il traffico sta venendo dirottato.

Step 2: La Mitigazione Locale (Tabelle ARP Statiche)

Per difendersi dall'attacco senza toccare le configurazioni dello switch, la vittima può forzare il proprio sistema operativo a ignorare i pacchetti ARP dinamici ingannevoli, inserendo una regola statica (hardcoded) per il Default Gateway.

Fate pulire la cache inquinata e inserite la regola statica (sono necessari i privilegi di Amministratore/Root):

Su Windows (Terminale come Amministratore):

DOS

```
arp -d *
arp -s <IP_DEL_GATEWAY> <MAC_REALE_DEL_GATEWAY>
```

(Nota per i docenti: Su Windows 10/11, il comando arp classico potrebbe essere deprecato a favore di `netsh`. In tal caso usare: `netsh interface ipv4 add neighbors "Nome Scheda" <IP_GATEWAY> <MAC_REALE>`)

Su Linux/Kali:

Bash

```
sudo ip -s -s neigh flush all
sudo arp -s <IP_DEL_GATEWAY> <MAC_REALE_DEL_GATEWAY>
```

Step di Verifica Finale

Con la voce statica inserita, se la vittima lancia un `arp -a`, vedrà che il tipo di record per il gateway è passato da "dinamico" a "statico".

Se a questo punto l'attaccante riprova a lanciare `arpspoof`, il sistema operativo della vittima scarterà semplicemente i pacchetti falsificati, mantenendo il traffico saldamente indirizzato verso il MAC address reale del router. L'attacco è neutralizzato.

Denial of Service a Layer 2 - MAC Flooding

Mentre gli attacchi precedenti miravano a intercettare o dirottare il traffico, il **MAC Flooding** punta a mandare in crisi l'hardware dello switch, forzandolo a degradare le sue prestazioni di sicurezza.

Teoria: La CAM Table (Content Addressable Memory)

Ogni switch mantiene una tabella interna chiamata **CAM Table** (o *MAC Address Table*). Questa tabella associa ogni indirizzo MAC alla porta fisica a cui è collegato.

- **Il limite:** La memoria dello switch è finita (es. un Cisco 2960 può contenere circa 8.000 indirizzi).
- **L'attacco:** Se un attaccante inonda lo switch con migliaia di frame Ethernet, ognuno con un MAC address sorgente casuale e falso, la CAM Table si riempie in pochi secondi.
- **Fail-open mode:** Quando la tabella è piena, lo switch non sa più dove mandare i pacchetti. Per non interrompere il servizio, entra in modalità "fail-open" e inizia a comportarsi come un **Hub**: inoltra ogni pacchetto in arrivo su **tutte le porte** (flooding).

Laboratorio: Esecuzione con `macof`

Useremo **macof**, un tool della suite `dsniff` progettato specificamente per generare rumore a Layer 2.

1. **Lancio dell'attacco da Kali:** Apri il terminale e specifica l'interfaccia di rete:

Bash

```
# Inizia a inondare lo switch con MAC address casuali
sudo macof -i eth0
```

Vedrai scorrere migliaia di righe con indirizzi IP e MAC generati casualmente.

2. **Verifica sullo Switch (Visualizzare la CAM):** Mentre l'attacco è in corso, entra nella console dello switch Cisco per osservare il disastro in tempo reale.

Cisco CLI

```
# Visualizza l'intera tabella dei MAC address
Switch# show mac address-table
```

Per vedere quanti indirizzi sono stati memorizzati (utile per vedere il limite raggiunto)
Switch# show mac address-table count

Noterai che la tabella si riempirà istantaneamente con MAC address senza senso, tutti associati alla tua porta (es. Gi0/1).

Analisi dei Risultati e Mitigazione

Una volta che la CAM è piena, l'attaccante può semplicemente lanciare **Wireshark** e vedrà transitare tutto il traffico della rete (anche quello non destinato a lui), proprio come se fosse collegato a un vecchio hub.

Come bloccare il MAC Flooding?

La soluzione definitiva è la **Port Security**. Questa funzione permette di limitare il numero di MAC address che possono essere appresi da una singola porta.

Comandi di Hardening sul 2960:

Cisco CLI

```
Switch(config)# interface range fa0/1 - 24
Switch(config-if)# switchport mode access
Switch(config-if)# switchport port-security
Switch(config-if)# switchport port-security maximum 2
Switch(config-if)# switchport port-security violation shutdown
```

Con questa configurazione, se `macof` prova a inviare più di 2 MAC address differenti, lo switch spegne immediatamente la porta (`err-disable`), bloccando l'attaccante.

Dynamic Host Configuration Protocol - DHCP

Il Dynamic Host Configuration Protocol (DHCP) è uno dei servizi più critici e, paradossalmente, meno protetti di una rete locale. Essendo un protocollo basato su broadcast e privo di autenticazione, si presta a diverse tipologie di attacco che possono portare alla paralisi della rete (DoS) o all'intercettazione totale del traffico (MitM).

4.1 Tipologie di Attacchi DHCP

In ambito VA/PT, le principali minacce che analizzeremo sono:

1. **DHCP Starvation:** Un attacco di Denial of Service che esaurisce tutti gli indirizzi IP disponibili nel pool del server legittimo.

2. **Rogue DHCP Server:** L'introduzione di un server non autorizzato che distribuisce parametri di rete malevoli (Default Gateway e DNS controllati dall'attaccante).
3. **DHCP Spoofing/Release:** L'invio di messaggi falsificati per terminare forzatamente i lease degli altri client o per intercettare i messaggi di acknowledge.

4.2 DHCP Starvation: Teoria e Meccanica

L'attacco di **Starvation** (fame/esaurimento) sfrutta la natura "generosa" del server DHCP. Quando un client entra in rete, invia un pacchetto *DHCP Discover* in broadcast. Il server risponde con una *DHCP Offer* riservando un IP per quel MAC address.

L'attaccante utilizza un tool per inondare la rete con migliaia di pacchetti *DHCP Discover*, ognuno contenente un **MAC address sorgente differente e casuale**. Il server DHCP (che sia un router 4321 o un server Windows) esaurirà in pochi secondi l'intero spazio di indirizzamento disponibile nel pool.

Risultato: Qualsiasi nuovo dispositivo legittimo che tenterà di collegarsi alla rete rimarrà in stato di "Connettività limitata o assente" poiché non riceverà alcuna risposta dal server.

4.3 Laboratorio: Esecuzione con Yersinia

In questo scenario, utilizzeremo un **Cisco ISR 4321** come Server DHCP e una macchina **Kali Linux** come attaccante.

1. Setup del Server (Cisco ISR 4321)

Configurate il router per gestire il pool di indirizzi:

Cisco CLI

```
Router(config)# ip dhcp pool LAN_CLIENTS
Router(dhcp-config)# network 10.10.10.0 255.255.255.0
Router(dhcp-config)# default-router 10.10.10.1
Router(dhcp-config)# lease 0 1  ! Lease di un'ora per il test
```

2. Esecuzione dell'attacco (Kali Linux)

L'attaccante avvia Yersinia in modalità interattiva:

1. **Avvio:** `sudo yersinia -I`
2. **Selezione Interfaccia:** Premi `i`, seleziona l'interfaccia corretta e premi `Invio`.
3. **Cambio Protocollo:** Premi `g`, seleziona **DHCP** e premi `Invio`.
4. **Lancio Attacco:**

- Premi `x` per aprire il pannello degli attacchi.
- Seleziona `1 - sending RAW DHCP discover packets`.
- Premi `Invio`.

5. **Verifica:** Osserva il contatore dei pacchetti inviati nella schermata principale. Dopo circa 20 secondi, ferma l'attacco premendo `L`, selezionando l'attacco e cancellandolo (o chiudendo Yersinia con `q`).

3. Verifica sul Router

Eseguite il comando per vedere come il pool è stato saturato:

Cisco CLI

```
Router# show ip dhcp binding
! Vedrete centinaia di righe con MAC address casuali
Router# show ip dhcp server statistics
! Il contatore delle "Active Bindings" dovrebbe corrispondere alla dimensione
del pool
```

Blue Team: Strategie di Mitigazione

La difesa contro la Starvation deve essere implementata sullo **Switch di accesso (Cisco 2960)**, poiché è l'apparato che vede fisicamente il traffico dei client.

1. DHCP Snooping

Questa è la difesa principale. Lo switch monitora i messaggi DHCP e permette i pacchetti di "risposta" (Offer/Ack) solo dalle porte fidate.

Cisco CLI

```
Switch(config)# ip dhcp snooping
Switch(config)# ip dhcp snooping vlan 10
! Definiamo la porta verso il router 4321 come TRUSTED
Switch(config)# interface Gi0/1
Switch(config-if)# ip dhcp snooping trust
```

2. Rate Limiting (Protezione specifica dalla Starvation)

Per bloccare l'inondazione di pacchetti *Discover* tipica di Yersinia, limitiamo il numero di pacchetti DHCP al secondo su ogni porta client.

Cisco CLI

```
Switch(config)# interface range fa0/1 - 24
Switch(config-if)# ip dhcp snooping limit rate 10
```

*Se un attaccante supera i 10 pacchetti DHCP al secondo, lo switch metterà la porta in stato di **err-disable**, bloccando l'attacco sul nascere.*

3. Port Security

Poiché la Starvation di Yersinia usa MAC address falsificati all'interno del pacchetto DHCP, il **Port Security** (visto nel Cap. 3) è un alleato fondamentale: se lo switch vede troppi MAC sorgenti diversi provenire dalla stessa porta fisica, bloccherà l'interfaccia prima ancora che il server DHCP venga saturato.

In un attacco di Rogue DHCP, l'attaccante non è obbligato a rispettare il piano di indirizzamento IP legittimo della rete. Anzi, in un contesto di Penetration Testing professionale, spesso è preferibile "spostare" la vittima su una **Shadow Network**: una sottorete completamente diversa da quella ufficiale (es. la vittima si aspetta la `10.10.10.0/24` e noi le assegniamo la `172.16.1.0/24`).

Perché utilizzare una Subnet diversa?

1. **Eliminazione dei conflitti IP:** Se usassimo la stessa subnet del router legittimo, rischieremmo di assegnare un IP già in uso, causando alert di sistema sulla vittima o collisioni ARP che renderebbero l'attacco instabile e rumoroso.
2. **Isolamento Logico:** Spostando la vittima su una rete che esiste solo nella memoria della macchina Kali, l'attaccante diventa l'unica autorità di routing. Il traffico della vittima non verrà mai intercettato o "corretto" dai gateway legittimi (come l'ISR 4321 o l'8000v).
3. **Trasparenza del MitM:** Attraverso il NAT (Network Address Translation), l'attaccante può far navigare la vittima verso internet facendole credere che tutto sia normale, mentre ogni singolo pacchetto viene decifrato e analizzato localmente.

Laboratorio: Configurazione della Shadow Network su Kali

Per rendere efficace questo attacco, la macchina Kali deve essere pronta a gestire una rete che ufficialmente non esiste sullo switch.

Step 1: Alias IP sull'interfaccia di Kali

Affinché Kali possa comunicare con la vittima sulla nuova rete (es. `172.16.1.0/24`), deve possedere un IP in quella subnet. Invece di cambiare l'IP principale, creiamo un alias:

Bash

```
# Sostituisci eth0 con la tua interfaccia bridge
sudo ip addr add 172.16.1.1/24 dev eth0
```

Step 2: Abilitazione del NAT (Masquerading)

Per permettere alla vittima di uscire su internet tramite Kali (che userà la sua connessione legittima), dobbiamo configurare il kernel Linux affinché faccia da router NAT:

Bash

```
# 1. Abilita l'IP Forwarding (se non già fatto)
sudo sysctl -w net.ipv4.ip_forward=1

# 2. Configura IPTables per il masquerading
# Assumi che eth0 sia l'interfaccia verso la rete del lab
sudo iptables -t nat -A POSTROUTING -o eth0 -j MASQUERADE
sudo iptables -A FORWARD -i eth0 -j ACCEPT
```

Step 3: Lancio del Rogue Server con Yersinia

Configurate Yersinia (tasto `x` -> opzione 2) con i parametri della Shadow Network:

- **Pool Start/End:** `172.16.1.100` - `172.16.1.200`
- **Subnet Mask:** `255.255.255.0`
- **Default Gateway:** `172.16.1.1` (L'IP di Kali)
- **DNS Server:** `172.16.1.1` (O un DNS pubblico come `8.8.8.8`)

Verifica dell'Attacco (Post-Exploitation)

Una volta che la vittima ha ottenuto l'IP dalla Shadow Network, lo studente deve verificare la totale sottomissione del traffico:

1. **Analisi sulla Vittima:**
   - `ipconfig /all` (Windows) o `ip a` (Linux): Verificare che l'IP appartenga alla rete `172.16.1.x`.
   - `tracert 8.8.8.8`: Il primo salto deve essere obbligatoriamente l'IP di Kali (`172.16.1.1`).
2. **Analisi sull'Attaccante (Kali):**
   - Eseguire `tcpdump -i eth0 icmp` e chiedere alla vittima di fare un ping.
   - **Risultato atteso:** Vedrete passare i pacchetti della vittima attraverso Kali. Ora potete lanciare tool di sniffing come **Wireshark** o **Bettercap** per catturare password o sessioni HTTP.

Nota di Troubleshooting: Se la vittima riceve ancora l'IP dal router legittimo, significa che il router è stato più veloce di Kali. In questo caso, è necessario lanciare un attacco di **DHCP Starvation** (visto nel paragrafo 4.2) per "zittire" il router prima di riprovare con il Rogue Server.

7.2 Dynamic ARP Inspection (DAI) - Blindare l'ARP

Il DAI è una funzione di sicurezza che intercetta, logga e scarta i pacchetti ARP con associazioni IP-to-MAC non valide.

Il meccanismo di funzionamento

Per poter decidere se un pacchetto ARP è legittimo o meno, lo switch ha bisogno di una "fonte di verità". Il DAI utilizza il database creato dal **DHCP Snooping**. Se un pacchetto ARP arriva su una porta non fidata, lo switch controlla se l'accoppiata IP/MAC nel pacchetto corrisponde a una voce nel database DHCP Snooping. Se non c'è corrispondenza, il pacchetto viene scartato.

Step 1: Il prerequisito (DHCP Snooping)

Senza DHCP Snooping, il DAI non sa quali siano gli IP legittimi assegnati agli host.

Cisco CLI

```
Switch(config)# ip dhcp snooping
Switch(config)# ip dhcp snooping vlan 10
# Impostiamo come "trusted" la porta verso il server DHCP reale
(Uplink)
Switch(config)# interface GigabitEthernet 0/0
Switch(config-if)# ip dhcp snooping trust
```

Step 2: Configurazione del DAI

Una volta attivo il database, abilitiamo l'ispezione sulla VLAN interessata.

1. **Abilitazione globale per VLAN:**

   Cisco CLI

   ```
   Switch(config)# ip arp inspection vlan 10
   ```

2. **Configurazione delle porte Trusted:** Di default, tutte le porte sono "untrusted" (ispezionate). Dobbiamo dire allo switch di non ispezionare i pacchetti ARP provenienti da altri switch o router (Uplink).

   Cisco CLI

```
Switch(config)# interface GigabitEthernet 0/0
Switch(config-if)# ip arp inspection trust
```

3. **Controlli di validazione extra (Opzionale ma consigliato):** Possiamo forzare lo switch a controllare non solo l'IP, ma anche la coerenza dei MAC address nell'intestazione Ethernet.

   Cisco CLI

   ```
   Switch(config)# ip arp inspection validate src-mac dst-mac ip
   ```

Step 3: Verifica e Troubleshooting

Se un utente prova a lanciare un attacco di ARP Spoofing (o se un host ha un IP statico non registrato), lo switch genererà dei log e bloccherà i pacchetti.

- **Vedere lo stato del DAI:**

  Cisco CLI

  ```
  Switch# show ip arp inspection vlan 10
  ```

- **Vedere le statistiche dei pacchetti scartati (per scovare l'attaccante):**

  Cisco CLI

  ```
  Switch# show ip arp inspection statistics
  ```

Nota per gli studenti: Se un host ha un **IP statico**, il DHCP Snooping non lo vedrà e il DAI lo bloccherà. In questi casi bisogna creare manualmente una **ARP Access List** per permettere quel traffico specifico.

Riassunto della logica Trusted vs Untrusted

Tipo Porta	Comportamento DAI	Utilizzo tipico
Untrusted (Default)	Ispeziona ogni pacchetto ARP contro il database.	Porte collegate a PC, Stampanti, Kali Linux.
Trusted	Accetta tutti i pacchetti ARP senza controlli.	Porte collegate a Router, Server o altri Switch.

DNS Spoofing: Il controllo nominale tramite DHCP

Mentre nel Capitolo 3 abbiamo visto come il DNS Spoofing richieda una tecnica di intercettazione attiva (ARP Poisoning), l'attacco tramite **Rogue DHCP Server** rende questa fase estremamente più semplice e "pulita".

Poiché l'attaccante ha il controllo del campo **Option 6 (Domain Name Server)** nel pacchetto di risposta DHCP, può istruire la vittima a utilizzare la macchina Kali come unico server DNS della rete. In questo scenario, non c'è bisogno di intercettare query dirette a server terzi: la vittima invierà *volontariamente* ogni sua richiesta di risoluzione all'attaccante.

La catena di compromissione:

1. **Rilevamento:** La vittima si connette e riceve un IP dal Rogue Server.
2. **Configurazione:** Il resolver della vittima viene impostato sull'IP di Kali (es. `172.16.1.1`).
3. **Risoluzione:** Quando l'utente cerca `www.bancapopolare.it`, la query UDP 53 arriva direttamente a Kali.
4. **Spoofing:** Un tool sull'attaccante (come `dnschef` o `bettercap`) intercetta la richiesta e risponde con l'IP di un server malevolo o di una pagina di phishing, inoltrando invece le richieste "non interessanti" ai veri DNS di Google (`8.8.8.8`) per non destare sospetti.

Vantaggio tattico: A differenza dell'ARP Spoofing, che può causare instabilità di rete o essere rilevato da sistemi IDS (come l'Arpwatch), il DNS Spoofing via DHCP è estremamente silenzioso a livello di protocollo, poiché si basa su un'interazione client-server perfettamente standard. La vittima non vedrà mai "due MAC address per lo stesso IP", ma semplicemente un server DNS che sta facendo il suo lavoro.

Sicurezza delle VLAN e VLAN Hopping

In una rete aziendale, le VLAN servono a isolare il traffico (es. VLAN Guest separata dalla VLAN Server). Tuttavia, la segmentazione non è magica: se l'infrastruttura non è configurata correttamente, un attaccante può "saltare" i confini delle VLAN senza passare per un firewall. Questo è il **VLAN Hopping**.

Anatomia dell'Attacco: Il "Trunk Misconfiguration"

Esistono due modi principali per eseguire il VLAN Hopping:

1. **Switch Spoofing (Abuso del DTP):** L'attaccante usa Yersinia per negoziare automaticamente un trunk.

2. **Fixed Trunk (Errore sistemistico):** L'amministratore lascia accidentalmente una porta host configurata come `trunk`. In questo caso, lo switch non chiede chi sei: accetta qualsiasi pacchetto taggato gli arrivi.

Laboratorio: Infiltrazione e Post-Exploitation

In questo scenario, simuliamo una porta switch (Gi0/1) erroneamente configurata come Trunk. Entreremo nella **VLAN 10 (Segreta)** e useremo Yersinia per attaccare i servizi interni.

1. Setup dello Switch (vIOS-L2)

Creiamo la zona protetta e apriamo il "tunnel" per l'attaccante:

Cisco CLI

```
Switch# conf t
Switch(config)# vlan 10
Switch(config-vlan)# name AREA_PROTETTA
Switch(config-vlan)# exit

Switch(config)# interface GigabitEthernet 0/1
Switch(config-if)# switchport trunk encapsulation dot1q
Switch(config-if)# switchport mode trunk
Switch(config-if)# no shutdown
```

2. Infiltrazione da Kali Linux (VLAN Hopping)

Dobbiamo dire al kernel Linux di gestire i tag 802.1Q per "parlare" con la VLAN 10.

Bash

```
# Carichiamo il modulo per il tagging
sudo modprobe 8021q

# Creiamo l'interfaccia virtuale legata alla VLAN 10
sudo ip link add link eth0 name eth0.10 type vlan id 10
sudo ip link set dev eth0.10 up

# Assegniamo un IP per muoverci nella nuova rete
sudo ip addr add 10.10.10.100/24 dev eth0.10
```

3. Attacco con Yersinia (Post-Exploitation)

Ora che Kali è "dentro" la VLAN 10, possiamo usare Yersinia per creare il caos nel segmento protetto:

- **STP Attack:** Diventare il Root Bridge della VLAN 10 per intercettare tutto il traffico (Sniffing).

- In Yersinia: g -> STP -> x -> `1 (Claiming Root Role)`.
- **DHCP Starvation:** Esaurire gli IP della VLAN 10 per bloccare i nuovi client legittimi.
  - In Yersinia: g -> DHCP -> x -> `1 (Raw Discover packets)`.

Blue Team: Mitigazione e Hardening

Proteggere le VLAN è semplice, ma richiede disciplina. Ecco le tre regole d'oro da applicare sul Catalyst 2960:

Azione	Comando Cisco	Perché farlo?
Forza modalità Access	`switchport mode access`	Impedisce alla porta di diventare un Trunk, anche se riceve pacchetti DTP.
Disabilita DTP	`switchport nonegotiate`	Spegne completamente il protocollo di negoziazione.
Cambia Native VLAN	`switchport trunk native vlan 999`	Impedisce l'attacco di **Double Tagging** (usando una VLAN inutilizzata).

Esporta in Fogli

Configurazione di Hardening consigliata:

Cisco CLI

```
Switch(config)# interface range fa0/1 - 24
Switch(config-if)# switchport mode access
Switch(config-if)# switchport nonegotiate
Switch(config-if)# spanning-tree bpduguard enable
```

7.2 Dynamic ARP Inspection (DAI) - Blindare l'ARP

Il DAI è una funzione di sicurezza che intercetta, logga e scarta i pacchetti ARP con associazioni IP-to-MAC non valide.

Il meccanismo di funzionamento

Per poter decidere se un pacchetto ARP è legittimo o meno, lo switch ha bisogno di una "fonte di verità". Il DAI utilizza il database creato dal **DHCP Snooping**. Se un pacchetto ARP arriva su una porta non fidata, lo switch controlla se l'accoppiata IP/MAC nel pacchetto corrisponde a una voce nel database DHCP Snooping. Se non c'è corrispondenza, il pacchetto viene scartato.

Step 1: Il prerequisito (DHCP Snooping)

Senza DHCP Snooping, il DAI non sa quali siano gli IP legittimi assegnati agli host.

Cisco CLI

```
Switch(config)# ip dhcp snooping
Switch(config)# ip dhcp snooping vlan 10
# Impostiamo come "trusted" la porta verso il server DHCP reale
(Uplink)
Switch(config)# interface GigabitEthernet 0/0
Switch(config-if)# ip dhcp snooping trust
```

Step 2: Configurazione del DAI

Una volta attivo il database, abilitiamo l'ispezione sulla VLAN interessata.

1. **Abilitazione globale per VLAN:**

   Cisco CLI

   ```
   Switch(config)# ip arp inspection vlan 10
   ```

2. **Configurazione delle porte Trusted:** Di default, tutte le porte sono "untrusted" (ispezionate). Dobbiamo dire allo switch di non ispezionare i pacchetti ARP provenienti da altri switch o router (Uplink).

   Cisco CLI

   ```
   Switch(config)# interface GigabitEthernet 0/0
   Switch(config-if)# ip arp inspection trust
   ```

3. **Controlli di validazione extra (Opzionale ma consigliato):** Possiamo forzare lo switch a controllare non solo l'IP, ma anche la coerenza dei MAC address nell'intestazione Ethernet.

   Cisco CLI

   ```
   Switch(config)# ip arp inspection validate src-mac dst-mac ip
   ```

Step 3: Verifica e Troubleshooting

Se un utente prova a lanciare un attacco di ARP Spoofing (o se un host ha un IP statico non registrato), lo switch genererà dei log e bloccherà i pacchetti.

- **Vedere lo stato del DAI:**

  Cisco CLI

  ```
  Switch# show ip arp inspection vlan 10
  ```

- **Vedere le statistiche dei pacchetti scartati (per scovare l'attaccante):**

Cisco CLI

```
Switch# show ip arp inspection statistics
```

Nota per gli studenti: Se un host ha un **IP statico**, il DHCP Snooping non lo vedrà e il DAI lo bloccherà. In questi casi bisogna creare manualmente una **ARP Access List** per permettere quel traffico specifico. Consultare la guida ufficiale Cisco:

https://www.cisco.com/c/en/us/td/docs/switches/lan/catalyst9500/software/release/17-15/configuration_guide/sec/b_1715_sec_9500_cg/configuring_dynamic_arp_inspection.pdf

---

Riassunto della logica Trusted vs Untrusted

Tipo Porta	Comportamento DAI	Utilizzo tipico
Untrusted (Default)	Ispeziona ogni pacchetto ARP contro il database.	Porte collegate a PC, Stampanti, Kali Linux.
Trusted	Accetta tutti i pacchetti ARP senza controlli.	Porte collegate a Router, Server o altri Switch.